

VibeSecSys Security Report

Summary of Findings

The scan shows a **highly exposed and likely insecure test or lab environment** with **48 open ports across 3 hosts**. Two hosts, **192.168.56.20** and **192.168.56.40**, expose a very large number of legacy and high-risk services, including:

- **Remote access services:** SSH, Telnet, VNC, X11
- **File sharing and network services:** FTP, NFS, SMB/NetBIOS
- **Database services:** MySQL, PostgreSQL
- **Java/application services:** Java RMI, AJP13, HTTP
- **Legacy/unsafe Unix services:** exec, login, shell, bindshell
- **Mail/DNS services:** SMTP, DNS

The host **192.168.56.30** is less exposed, with only **SSH and HTTP** open.

Overall, the environment presents **multiple critical attack surfaces**, especially on the two heavily exposed hosts.

Risks Identified

1. Exposure of insecure legacy services

The presence of **Telnet, FTP, exec, login, shell, and bindshell** services is a major concern. These services are outdated and often transmit data in plaintext or provide direct remote command execution.

Risk:

- Credential theft
 - Unauthorized remote access
 - Full host compromise
 - Easy lateral movement by attackers
-

2. Multiple remote administration interfaces

Open **SSH, Telnet, VNC, X11, and AJP13** indicate several remote management and application access paths.

Risk:

- Brute force attacks
 - Weak authentication exploitation
 - Session hijacking
 - Remote code execution if misconfigured or unpatched
-

3. Unnecessary database exposure

Both MySQL and PostgreSQL are exposed on the network.

Risk:

- Unauthorized database access
 - Data exfiltration
 - Privilege escalation through weak credentials or misconfiguration
 - Attackers using databases as footholds for deeper compromise
-

4. File-sharing and RPC service exposure

Services such as **NFS**, **rpcbind**, **SMB/NetBIOS** can be dangerous if improperly configured.

Risk:

- Unauthorized file access
 - Share enumeration
 - Credential harvesting
 - Exploitation of vulnerable RPC or SMB implementations
-

5. Web/application server attack surface

Open **HTTP on multiple ports** and **AJP13 on 8009** suggest web services and possibly a Java/Tomcat stack.

Risk:

- Web application vulnerabilities
 - Directory traversal
 - Remote code execution through known AJP/Tomcat issues if unpatched
 - Misconfigured admin interfaces
-

6. Mail and DNS service exposure

SMTP and DNS are exposed on the larger hosts.

Risk:

- SMTP relay abuse
 - Mail enumeration
 - DNS zone transfer or information leakage if misconfigured
-

7. Large attack surface and likely poor segmentation

The sheer number of services indicates either:

- a deliberately vulnerable lab image, or
- a severely overexposed host with poor service hardening.

Risk:

- Simplified attacker reconnaissance
 - High probability of exploitability
 - Increased chance of privilege escalation and persistence
-

Misconfigurations

1. Unnecessary services enabled

Many services appear to be running simultaneously, especially on 192.168.56.20 and 192.168.56.40.

Examples:

- Telnet
- FTP
- exec/login/shell services
- Bind shell
- IRC
- X11

These are rarely needed in production and should likely not be exposed.

2. Plaintext authentication services

- **Telnet**
- **FTP**
- possibly **SMTP** depending on configuration

These services can expose credentials in cleartext.

3. Internal databases exposed externally on the local network

MySQL and PostgreSQL are listening on network interfaces rather than being restricted to localhost or a trusted subnet.

4. Potentially unsafe RPC/NFS/SMB configuration

Open **rpcbind**, **NFS**, **SMB/NetBIOS**, and related services suggest possible weak access controls or broad network exposure.

5. AJP13 service exposed

AJP should generally not be publicly accessible and should be restricted to trusted backend communication only.

6. Multiple management services without evidence of access restriction

SSH, VNC, and X11 exposure suggests possible lack of firewall filtering or host-based access control.

Recommendations

Priority 1: Remove or disable high-risk legacy services

Immediately disable or isolate:

- **Telnet**
- **FTP**
- **exec/login/shell**
- **bindshell**
- **X11** exposure if not required
- **IRC** if not required

These services are high risk and should not be exposed on a network.

Priority 2: Restrict access to management and database services

Limit access to:

- **SSH**
- **VNC**
- **MySQL**
- **PostgreSQL**
- **AJP13**
- **RPC/NFS/SMB**

Use:

- Host-based firewalls
 - Network ACLs
 - VPN or jump hosts
 - IP allowlists
-

Priority 3: Enforce secure protocols

Replace or secure plaintext services:

- Replace **FTP** with **SFTP/FTPS**
 - Replace **Telnet** with **SSH**
 - Ensure **SMTP** uses authentication and encryption where appropriate
 - Disable anonymous access where possible
-

Priority 4: Harden web and Java services

For hosts exposing **HTTP/AJP13**:

- Patch Tomcat/web server components
 - Disable AJP if not needed
 - Bind AJP to localhost or internal interfaces only
 - Review web app permissions and admin endpoints
 - Scan web apps for common vulnerabilities
-

Priority 5: Secure file-sharing services

For **NFS, SMB, rpcbind**:

- Restrict to trusted subnets
 - Disable export/share access to unauthorized hosts
 - Review export permissions
 - Ensure SMB signing and modern protocol versions where applicable
-

Priority 6: Harden remote access

For **SSH, VNC, and any admin interface**:

- Use strong passwords or key-based authentication
 - Disable root login over SSH
 - Enable MFA where possible
 - Rate limit login attempts
 - Log and monitor authentication attempts
-

Priority 7: Apply patching and service inventory review

- Identify why each service is running
 - Remove unneeded packages
 - Patch all exposed services and OS components
 - Verify whether these hosts are intentionally vulnerable test systems
-

Priority 8: Segment the environment

If this is not a lab:

- Place databases, management services, and internal-only services on separate network segments
 - Use firewall zones to separate user-facing services from backend services
 - Minimize lateral movement paths
-

Overall Risk Rating

High to Critical

Reason:

- Multiple legacy insecure services are exposed

- Several services are known to be commonly abused for remote compromise
- Databases and file-sharing services are network-accessible
- There is strong indication of poor hardening and weak segmentation

If you want, I can also turn this into a **formal vulnerability assessment report** with **severity ratings per host/service**.